

El HHS resume la norma de seguridad. Revisa los siguientes extractos de ese resumen para obtener más información sobre la privacidad de los datos, la seguridad y los requisitos de respaldo relacionados con el programa de ciberseguridad de Cedarville Family Health.

Nota: Estos extractos provienen de la siguiente fuente:

– Resumen de la norma de seguridad de la ley HIPAA. *Departamento de Salud y Servicios Humanos de EE. UU.*, 19 de octubre de 2022.

Norma de seguridad (extractos)

Introducción

Uno de los objetivos principales de la norma de seguridad es proteger la privacidad de la información médica de las personas y,

al mismo tiempo, permitir que las entidades sujetas adopten nuevas tecnologías para mejorar la calidad y la eficiencia de la atención al paciente. Dado que el mercado de la atención médica es diverso, la norma de seguridad está diseñada para ser flexible y escalable, de modo que una entidad sujeta pueda implementar políticas,

procedimientos y tecnologías que sean apropiados para el tamaño particular de la entidad, su estructura organizacional y los riesgos para la [información médica protegida en formato electrónico (e-PHI)] de los consumidores.

Antecedentes legales y reglamentarios

La ley HIPAA apeló al Secretario [del Departamento de Salud y Servicios Humanos (HHS)] para que emitiera normas de seguridad con respecto a las medidas para proteger la integridad, confidencialidad y disponibilidad de la e-PHI que conservan o transmiten las entidades sujetas. El HHS desarrolló la norma

propuesta... La norma establece de manera específica una serie de procedimientos de seguridad administrativos, técnicos y físicos que las entidades sujetas deben utilizar para garantizar la confidencialidad, integridad y disponibilidad de la e-PHI.

Normas generales

La norma de seguridad exige a las entidades sujetas:

1. Mantener medidas de protección administrativas, técnicas y físicas, razonables y apropiadas, para proteger la e-PHI;
2. Garantizar la confidencialidad, integridad y disponibilidad de toda la información médica protegida en formato electrónico que creen, reciban, mantengan o transmitan;
3. Identificar y protegerse ante amenazas razonablemente

- previstas contra la seguridad o integridad de la información;
4. Protegerse contra usos o divulgaciones no permitidos y razonablemente previstos y
 5. Garantizar el cumplimiento por parte de su fuerza laboral.

La norma de seguridad define “confidencialidad” en el sentido de que la información médica protegida en formato electrónico no esté disponible ni se divulgue a personas no autorizadas.

El HHS reconoce que las entidades sujetas varían desde los proveedores más pequeños hasta el plan de salud más grande que abarca varios estados. Por lo tanto, la norma de seguridad es flexible y escalable para permitir que las entidades sujetas analicen sus propias necesidades e implementen soluciones apropiadas para sus entornos específicos. Lo que sea apropiado para una entidad sujeta

en particular dependerá de la naturaleza de la actividad de esa entidad, [y] del tamaño y los recursos de la entidad sujeta.

Por lo tanto, cuando una entidad sujeta decide qué medidas de seguridad emplear, la norma no impone esas medidas, sino que establece que la entidad sujeta considere:

-
- Su tamaño, complejidad y capacidades,
 - Su infraestructura técnica, de hardware y de software,
 - Los costos de las medidas de seguridad y
 - La probabilidad y el posible impacto de los riesgos potenciales para la información médica protegida en formato electrónico.

Las entidades sujetas deben revisar y modificar sus medidas de seguridad para seguir protegiendo la e-PHI en un entorno cambiante.

Revisar el análisis y gestión de riesgos

Nota: Estos extractos provienen de la siguiente fuente:

Resumen de la norma de seguridad de la ley HIPAA. *Departamento de Salud y Servicios Humanos de EE. UU.*, 19 de octubre de 2022.

Norma de seguridad (extractos)

Análisis y gestión de riesgos

- Las disposiciones sobre medidas de protección administrativas de la norma de seguridad exigen que las entidades sujetas realicen análisis de riesgos como parte de sus procesos de gestión de la seguridad. Las disposiciones sobre análisis y gestión de riesgos de la norma de seguridad se abordan aquí por separado porque, al

ayudar a determinar qué medidas de seguridad son razonables y adecuadas para una entidad sujeta en particular, el análisis de riesgos afecta a la aplicación de todas las medidas de protección contenidas en la norma de seguridad.

- Un proceso de análisis de riesgos incluye, entre otras, las siguientes actividades:
 - Evaluar la probabilidad y el impacto de los riesgos potenciales

para la e-PHI;

- Aplicar las medidas de seguridad adecuadas para hacer frente a los riesgos identificados en el análisis de riesgos;
- Documentar las medidas de seguridad elegidas y, cuando sea necesario, la justificación de la adopción de dichas medidas; y
- Mantener protecciones de seguridad continuas, razonables y adecuadas.

El análisis de riesgos debe ser un proceso continuo, en el que una entidad sujeta revisa de manera periódica sus registros para rastrear el acceso a la e-PHI y detectar incidentes de seguridad, evalúa regularmente la eficacia de las medidas de seguridad establecidas y reevalúa periódicamente los riesgos potenciales para la e-PHI.

Norma de seguridad (extractos)

Medidas de protección administrativas

- **Proceso de gestión de la seguridad.** Como se explica en la sección anterior, una entidad sujeta debe identificar y analizar los riesgos potenciales para la e-PHI y debe aplicar medidas de seguridad que reduzcan los riesgos y vulnerabilidades a un nivel razonable y apropiado.

- **Personal de seguridad.** Una entidad sujeta debe designar a un responsable de seguridad que se encargue de desarrollar y aplicar sus políticas y procedimientos de seguridad.
- **Gestión del acceso a la información.** En consonancia con la norma de privacidad que limita el uso y divulgación de la PHI al “mínimo necesario”, la norma de seguridad exige que una entidad sujeta aplique políticas y procedimientos para autorizar el acceso a la e-PHI solo cuando dicho acceso sea apropiado en virtud de la función del usuario o destinatario (acceso basado en funciones).
- **Capacitación y gestión del personal.** Una entidad sujeta debe prever la autorización y supervisión adecuadas de los miembros del personal que trabajen con la e-PHI. Una entidad sujeta debe capacitar a todos los empleados en relación con sus políticas y procedimientos de seguridad; además, debe contar con sanciones apropiadas que se aplicarán a los empleados que infrinjan sus políticas y procedimientos.
- **Evaluación.** Una entidad sujeta debe realizar una evaluación periódica de la medida en que sus políticas y procedimientos de seguridad cumplen los requisitos de la norma de seguridad.

Norma de seguridad (extractos)

Medidas de protección física

- **Acceso y control de las instalaciones.** Una entidad sujeta debe limitar el acceso físico a sus instalaciones y garantizar que se permita el acceso autorizado.
- **Seguridad de las estaciones y dispositivos de trabajo.** Una entidad sujeta debe aplicar políticas y procedimientos para

especificar el uso y acceso adecuados a las estaciones de trabajo y los medios electrónicos. Una entidad sujeta también debe contar con políticas y procedimientos establecidos con respecto a la transferencia, eliminación, disposición y reutilización de medios electrónicos, para garantizar la protección adecuada de la información médica protegida en formato electrónico (e-PHI). La ley HIPAA apeló al Secretario [del Departamento de Salud y Servicios Humanos (HHS)] para que emitiera normas de seguridad

con respecto a las medidas para proteger la integridad, confidencialidad y disponibilidad de la e-PHI que conservan o transmiten las entidades sujetas. El HHS desarrolló la norma propuesta... La norma establece de manera específica una serie de procedimientos de seguridad administrativos, técnicos y físicos que las entidades sujetas deben utilizar para garantizar la confidencialidad, integridad y disponibilidad de la e-PHI.

Normas generales

La norma de seguridad exige a las entidades sujetas:

1. Mantener medidas de protección administrativas, técnicas y físicas, razonables y apropiadas, para proteger la e-PHI.
2. Garantizar la confidencialidad, integridad y disponibilidad de toda la información médica protegida en formato electrónico que creen, reciban, mantengan o transmitan;

3. Identificar y protegerse ante amenazas razonablemente previstas contra la seguridad o integridad de la información;
4. Protegerse contra usos o divulgaciones no permitidos y razonablemente previstos; y
5. Garantizar el cumplimiento por parte de su fuerza laboral.

La norma de seguridad define “confidencialidad” en el sentido de

que la información médica protegida en formato electrónico no esté disponible ni se divulgue a personas no autorizadas.

El HHS reconoce que las entidades sujetas varían desde los proveedores más pequeños hasta el plan de salud más grande que abarca varios estados. Por lo tanto, la norma de seguridad es flexible y escalable para permitir que las entidades sujetas analicen sus propias necesidades e implementen soluciones apropiadas para sus entornos específicos. Lo que sea apropiado para una entidad sujeta

en particular dependerá de la naturaleza de la actividad de esa entidad, [y] del tamaño y los recursos de la entidad sujeta.

Por lo tanto, cuando una entidad sujeta decide qué medidas de seguridad emplear, la norma no impone esas medidas, sino que establece que la entidad sujeta considere:

- Su tamaño, complejidad y capacidades,
- Su infraestructura técnica, de hardware y de software,
- Los costos de las medidas de seguridad y
- La probabilidad y el posible impacto de los riesgos potenciales para la información médica protegida en formato electrónico.

Las entidades sujetas deben revisar y modificar sus medidas de seguridad para seguir protegiendo la información médica protegida

Norma de seguridad (extractos)

Medidas de protección técnica

- **Control de acceso.** Una entidad sujeta a esta norma debe aplicar políticas y procedimientos técnicos que permitan que solo las personas autorizadas tengan acceso a la información médica protegida en formato electrónico (e-PHI).

- **Controles de auditoría.** Una entidad sujeta debe poner en práctica

mecanismos de hardware, software [y] procedimientos para registrar y examinar el acceso y demás actividades en los sistemas de información que contengan o utilicen información médica protegida en formato electrónico.

- **Controles de integridad.** Una entidad sujeta debe aplicar políticas y procedimientos para garantizar que la e-PHI no se altere o destruya de forma indebida. Deben establecer medidas electrónicas para confirmar que la e-PHI no fue alterada o

destruida indebidamente.

- **Seguridad en la transmisión.** Una entidad cubierta debe aplicar medidas de seguridad técnicas que impidan el acceso no autorizado a la e-PHI que se transmite a través de una red electrónica.